Lab 25 — Network IDS with Suricata

You will run Suricata in IDS mode, load community rules, trigger an alert with a known signature, then write a custom rule.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free, apt): - `suricata` - `jq` - `curl` (pre-installed)

Step 1 — Install

```
apt update && apt install -y suricata jq
```

```
suricata-update
```

`suricata-update` pulls the free Emerging Threats Open ruleset (~30 000 signatures).

Step 2 — Identify the live interface

```
ip -brief link
```

```
IFACE=$(ip route | awk '/default/ {print $5; exit}')
```

```
echo "Listening on $IFACE"
```

Step 3 — Run Suricata in IDS mode (foreground)

```
suricata -i $IFACE -l /var/log/suricata --runmode workers -D

sleep 5

ls /var/log/suricata
```

`-D` daemonises. Output goes to `eve.json`.

Step 4 — Trigger the EICAR alert (always present in ET Open)

```
curl -s --user-agent "test" "http://testmynids.org/uid/index.html"

sleep 3

jq -c 'select(.event_type=="alert") | {sig:.alert.signature,
src:.src_ip, dst:.dest_ip}' /var/log/suricata/eve.json | tail
```

You should see `GPL ATTACK_RESPONSE id check returned root`.

Step 5 — Write a custom signature

```
mkdir -p /etc/suricata/rules

cat > /etc/suricata/rules/lab.rules <<'EOF'

alert http any any -> any any (msg:"LAB SQL injection attempt"; \
    flow:to_server; content:"' OR '1'='1"; sid:9000001; rev:1;)

alert http any any -> any any (msg:"LAB curl user-agent"; \
    http.user_agent; content:"curl/"; sid:9000002; rev:1;)

EOF

# include the file
```

```
sed -i '/^rule-files:/a\  - /etc/suricata/rules/lab.rules' /etc/suricata/suricata.yaml

suricatasc -c reload-rules 2>/dev/null || (kill $(pidof suricata); suricata -i $IFACE -l /var/log/suricata -D)
```

Trigger:

```
sleep 3

curl -s "http://example.com/?id=' OR '1'='1" >/dev/null

sleep 2

jq -c 'select(.alert.signature_id>=9000001) | {sig:.alert.signature, ua:.http.http_user_agent}' /var/log/suricata/eve.json | tail
```

Step 6 — IDS vs. IPS

In `suricata.yaml` change to inline NFQUEUE / AF_PACKET to switch from **IDS** (alert) to **IPS** (drop). The same rule set then *blocks* traffic.

Free online tools

- **Emerging Threats Open ruleset** — https://rules.emergingthreats.net
- **Snort 3 community rules** — https://www.snort.org/downloads
- **Zeek (network monitoring)** — https://zeek.org
- **Security Onion (SOC distro)** — https://securityonionsolutions.com

- **MITRE D3FEND** — https://d3fend.mitre.org

What you learned

- The structure of a Suricata rule (action, proto, direction, content, sid).
- Why SOC analysts grep the `eve.json` lines for `event_type=alert`.
- The single-flag difference between an IDS and an inline IPS.